Chain Of Product

Network and Computer Security

Afonso Rosa 106700
Lourenço Calhau 103396
Nickolas Ficker 116178

Table of contents

01 Secure document format

02 Built infrastructure

03 Secure channels

04 Security challenge

05 Key distribution

06 Results and conclusion

Chain of Product Scenario

- Business setting of mutually distrusting companies, Transaction Server acts as a mediator.
- DvP transactions are JSON documents with sensitive business data.
- Transaction Server & Database are **trusted** but have no access to the content of the transactions.

```
{
  "id": "doc-001",
  "timestamp": 17663363400,
  "seller": "alice",
  "buyer": "bob",
  "product": "Indium",
  "units": 40000,
  "amount": 90000000
}
```

01

Secure document format

Secure Document – Format

DvP Transaction

```
{
  "id": "doc-001",
  "timestamp": 17663363400,
  "seller": "alice",
  "buyer": "bob",
  "product": "Indium",
  "units": 40000,
  "amount": 90000000
}
```

Secure Document Output:

```
{
  "sender":"alice",
  "receiver":"bob",
  "timestamp":"1.76633634E10",
  "seq_num":"1.0",
  "content_cipher":"diMgD1CEobOUBqKSXD..."
}
```

Document

```
c7yoJVFcDPl0hvF+xEtHBu6kU0t...
```

Transaction Key

```
SJldK/eWVgzi7GF32zQHcjBfIqB6...
```

Agreement Signature

Transactions and their Metadata

- The transactions are stored in the DB alongside their **metadata**.
- Access control and security requirements are enforced with the help of the metadata.

Metadata holds:

➔ **List of encrypted transaction keys** (sharedKeys[]): K_tx wrapped with RSA.

➔ **Agreement signatures**: seller/buyer signatures over the transaction.

➔ **Share logs**: list of who the transaction was shared with and by who.

02

Built infrastructure

System components

Client

Java (JAX-RS Client API)

Group Server

Java Jakarta EE (JAX-RS)

Transaction Server

Java Jakarta EE (JAX-RS)

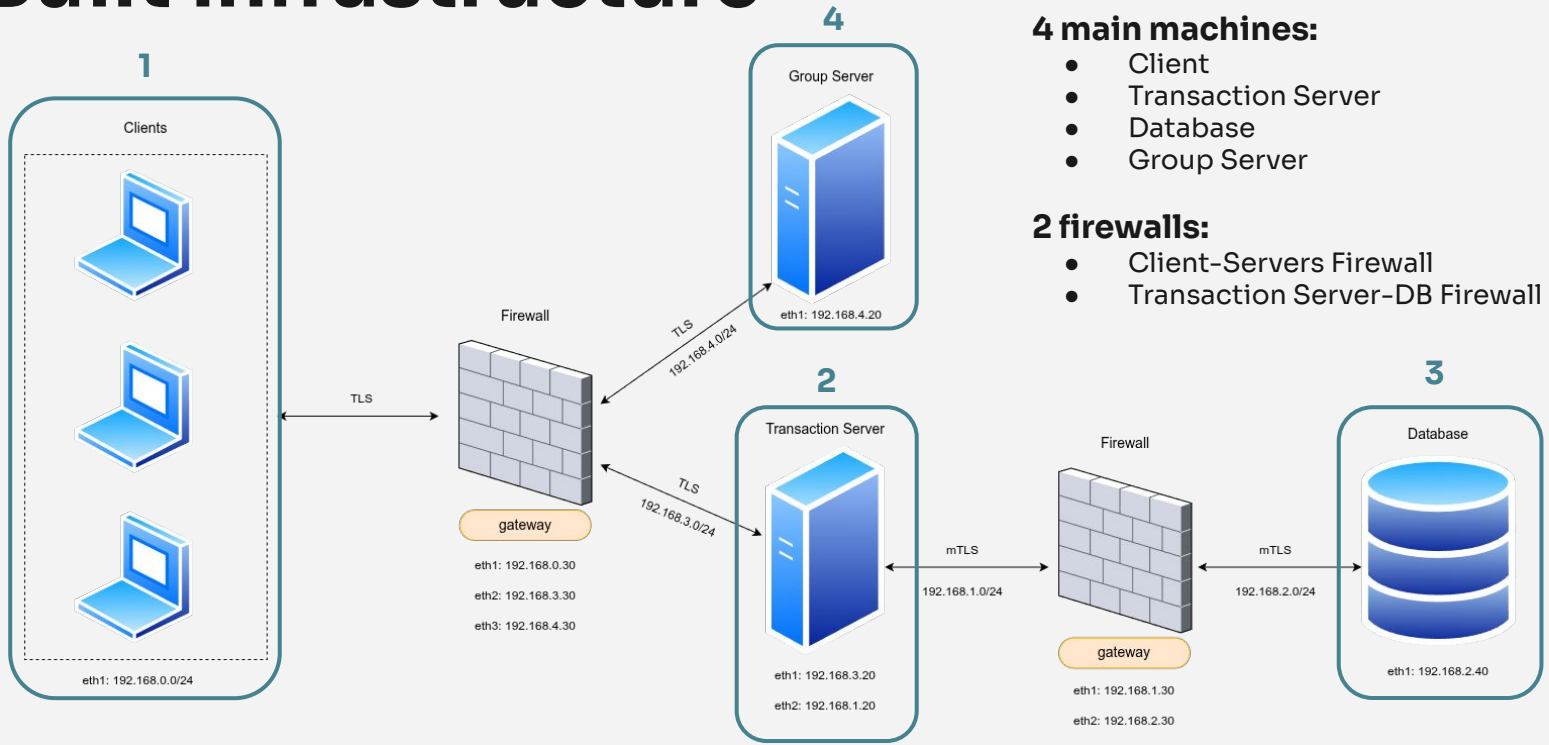
Database

PostgreSQL + Docker

Firewalls

iptables

Built infrastructure



4 main machines:

- Client
- Transaction Server
- Database
- Group Server

2 firewalls:

- Client-Servers Firewall
- Transaction Server-DB Firewall

Built infrastructure

Additional Security - IP Table rules

Transaction Server

- Address is unknown to clients
- Only accepts connections on **port 8443** from the Clients network.

Group Server

- Address is unknown to clients
- Only accepts connections on **port 8081** from the Clients network.

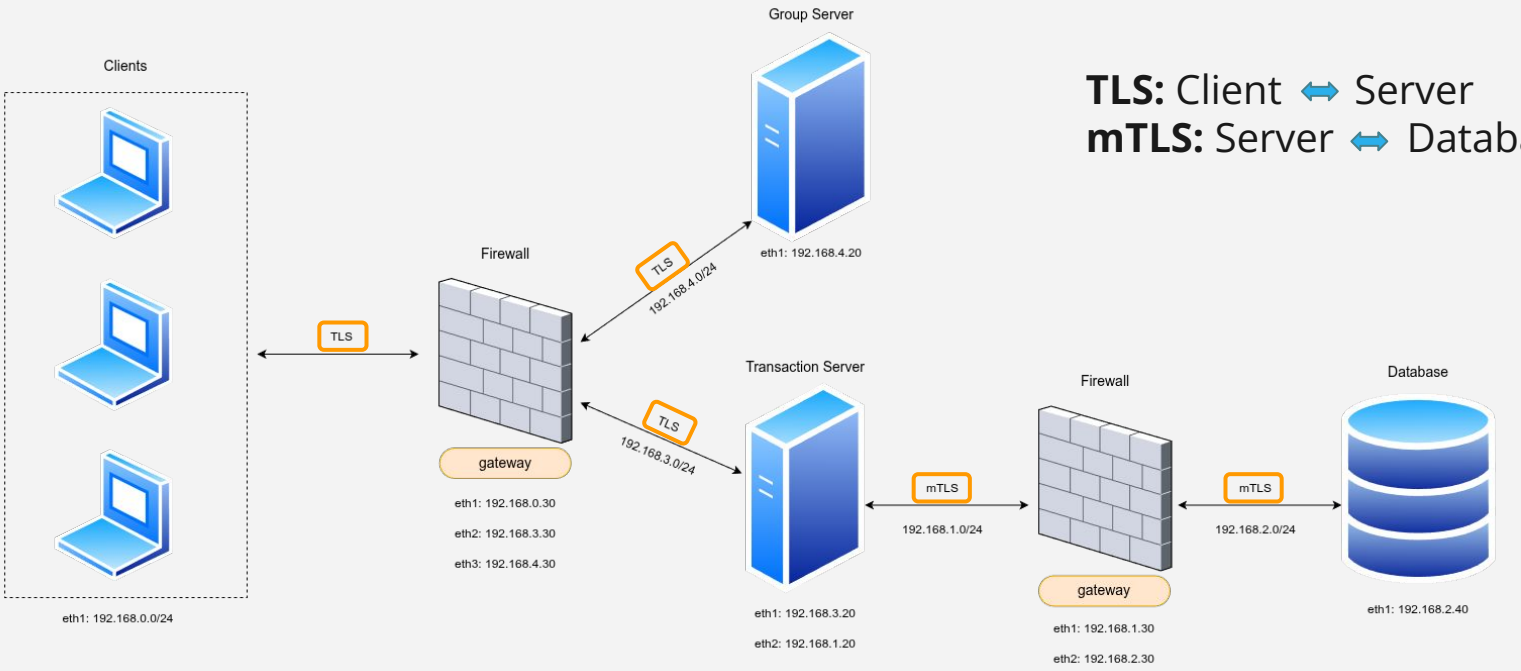
Database

- Only accepts connections on **port 5432** from the Transaction Server's IP address

03

Secure channels

Secure Channels



TLS: Client ⟺ Server
mTLS: Server ⟺ Database

04

Security challenge

Security challenge

Security Challenge A - Groups of partners

What changed

- New Group Server validates membership and controls transaction key access.
- The Group Server acts as a trusted gatekeeper
- The Transaction Server continues to handle individual disclosures and stores group-based shares, while delegating membership authorization to the Group Server

How it was implemented

- Group Server runs independently from the main Transaction Server
- The Group Server maintains a single key-pair to enable encryption/decryption of transaction keys shared with groups
- File-based storage that maps groups names to member lists (groups.json)

05

Key distribution

Key Distribution

User's Public Key

- Assumptions:

- Each user has access to every user's public key
- Each user assumes authenticity of pre-shared public keys

- RSA-2048 key pairs manually generated

Group Server's Key Pair

- Assumptions:

- Group Server is fully trusted by all users

- RSA-2048 key pair auto-generated at Group Server startup

- Group Server's public key retrieved dynamically via REST API

- Enables centralized access control through encryption

06

Results and conclusion

Results

Security requirements satisfied

- Confidentiality between buyer and seller is ensured via hybrid encryption
- Authentication on sharing is enforced through digital signatures
- Transaction integrity is maintained by using hashing
- Integrity of sharing lists is preserved through signed SharedLog entries

Security challenge implemented

- Group Server fully responsible for group management
- Isolated service, independent from the remaining system
- Parties are able to share transactions details with groups of partners

Conclusion

Main requirements and goals of the project were accomplished.

Possible future improvements:

- Public Key Infrastructure (PKI)
- Key revocation mechanism
- Web-based interface to improve usability